

# Анатомия уязвимости ZeroLogon (CVE-2020-1472): От эксплуатации до защиты инфраструктуры

 [redsec.by/article/anatomiya-uyazvimosti-zerologon-cve20201472-ot-ekspluatacii-do-zashity-infrastruktury](https://redsec.by/article/anatomiya-uyazvimosti-zerologon-cve20201472-ot-ekspluatacii-do-zashity-infrastruktury)

Red Teams | 24 марта 2026



В мире информационной безопасности редко появляются уязвимости, способные разрушить периметр доверия целой корпоративной сети за считанные секунды. ZeroLogon (CVE-2020-1472) — именно такой случай. Получив максимальный балл по шкале CVSS (10.0) и статус критической угрозы (Netlogon Elevation of Privilege Vulnerability), этот изъян перевернул представление о безопасности Active Directory.

В данном техническом руководстве мы разберем уязвимость на молекулярном уровне: от криптографических ошибок в протоколе Netlogon Remote Protocol (MS-NRPC) до практической эксплуатации в боевых условиях и выстраивания эшелонированной защиты. Это не просто обзор — это выжимка практического опыта тестирования на проникновение и реагирования на инциденты.

## 1. Архитектура аутентификации: Роль Netlogon и MS-NRPC

Для понимания вектора атаки необходимо глубоко погрузиться в механику работы службы Netlogon. Служба Netlogon реализует проприетарный RPC-интерфейс Microsoft Netlogon Remote Protocol (MS-NRPC). Этот протокол является кровеносной

системой Active Directory, отвечающей за аутентификацию и поддержание «защищенного канала» (Secure Channel).

## Основные функции MS-NRPC:

---

- Установление и проверка доверительных отношений между рабочими станциями (членами домена) и контроллерами домена (DC).
- Маршрутизация запросов аутентификации (например, NTLM сквозная аутентификация).
- Поддержание доверия между различными контроллерами внутри одного домена, а также между доверенными лесами.
- Синхронизация и обновление паролей машинных учетных записей (включая критически важные пароли самих контроллеров домена).

В отличие от Kerberos, Netlogon использует собственную криптографическую схему аутентификации. Она базируется на симметричной криптографии, где общим секретом (Shared Secret) выступает хеш пароля машинной учетной записи компьютера. После успешного рукопожатия генерируется сессионный ключ, который защищает дальнейший трафик.

**Важно:** Архитектурная проблема протокола заключалась в том, что он позволял клиенту выбирать уровень защиты сессии. До внедрения жестких политик (Enforcement Phase) клиент мог запросить аутентификацию без обязательного шифрования и подписи (RPC Sealing/Signing) последующих пакетов.

## 2. Криптографический коллапс: Суть CVE-2020-1472

---

Корень уязвимости ZeroLogon кроется в фатальной ошибке реализации режима шифрования AES-CFB8 (Advanced Encryption Standard в режиме Cipher Feedback с размером блока 8 бит) внутри функции ComputeNetlogonCredential.

### Теория режима AES-CFB8

---

Согласно стандартам криптографии, алгоритм CFB требует использования уникального и непредсказуемого вектора инициализации (Initialization Vector, IV) для каждой сессии. IV гарантирует, что шифрование одинаковых открытых текстов одним и тем же ключом даст разный шифртекст.

Математически шифрование первого байта в режиме CFB8 выглядит так:

$$C_1 = P_1 \oplus E_k(IV)$$

Где  $C_1$  — шифртекст,  $P_1$  — открытый текст,  $E_k$  — функция шифрования AES с сессионным ключом,  $\oplus$  — операция XOR.

## Ошибка реализации Microsoft

---

В реализации `ComputeNetlogonCredential` вектор инициализации был **жестко зафиксирован как 16 байтов нулей** ( $IV = 0$ ). Сама схема применялась к 8-байтовым сообщениям-челленджам (Client Challenge) без какой-либо рандомизации.

Если атакующий отправляет полностью нулевой открытый текст ( $P_1 = 0$ ) и вектор инициализации равен нулю ( $IV = 0$ ), уравнение принимает вид:

$$C_1 = 0 \oplus E_k(0)$$

Поскольку функция AES работает как псевдослучайная перестановка, результат  $E_k(0)$  является псевдослучайным значением. Однако, поскольку мы берем только первый байт (режим CFB8), вероятность того, что первый байт  $E_k(0)$  окажется равен нулю, составляет ровно  $\frac{1}{256}$ .

Если этот байт равен нулю, то:

$$C_1 = 0 \oplus 0 = 0$$

**Риски:** При многократной отправке нулевых запросов (в среднем 256 попыток) атакующий получает нулевой шифртекст. Netlogon воспринимает это как валидное криптографическое доказательство того, что клиент знает общий секрет (хеш пароля машины), тем самым успешно завершая аутентификацию.

## 3. Затронутые платформы и условия эксплуатации

---

Уязвимости подвержены все серверные ОС Windows, выполняющие роль контроллера домена со стандартными (до августа 2020 года) настройками:

- Windows Server 2008 R2 (Extended Security Updates)
- Windows Server 2012 / 2012 R2
- Windows Server 2016
- Windows Server 2019
- Samba (в роли AD DC до выпуска патчей в сентябре 2020)

В Windows Server 2022 данный изъян исправлен на уровне архитектуры базовой ОС.

## Условия для успешной атаки:

---

1. Сетевой доступ к контроллеру домена по TCP-портам RPC (обычно TCP/135 EndPoint Mapper и динамические порты RPC, например TCP/49152+).
2. Отсутствие патчей Microsoft (август 2020 и новее) или режима принудительного использования защищенного RPC.
3. Наличие маршрутизации до DC (L2/L3 связность).

**Никаких валидных учетных записей не требуется.** Атака проводится полностью анонимно (Unauthenticated).

## 4. Общая схема атаки ZeroLogon (Вектор Red Team)

---

В боевых условиях процесс захвата домена через ZeroLogon выглядит как четко отлаженный конвейер. Рассмотрим анатомию эксплуатации по шагам.

### Шаг 1: Инициализация соединения и брутфорс аутентификации

---

Атакующий устанавливает RPC-сессию с MS-NRPC и начинает бомбардировать контроллер домена вызовами NetrServerReqChallenge и NetrServerAuthenticate3. В качестве целевого аккаунта указывается имя машины самого контроллера домена (например, DC01\$).

Поля Client Challenge и Client Credential заполняются нулями. Через доли секунды (максимум пару минут) сервер отвечает успешной аутентификацией.

### Шаг 2: Отключение шифрования

---

При успешной аутентификации атакующий сбрасывает флаги, требующие обязательного шифрования последующего трафика (RPC Sealing). Это позволяет продолжать общение с сервером без знания реального сессионного ключа.

### Шаг 3: Обнуление пароля машинной учетной записи

---

Установив защищенный канал от имени DC01\$, атакующий вызывает функцию NetrServerPasswordSet2. Эта функция предназначена для легитимной смены пароля машины. Злоумышленник передает полностью нулевой криптованный payload, что приводит к установке пустого (пустого хеша) пароля для учетной записи контроллера домена в базе NTDS.DIT.

### Шаг 4: DCSync и полный захват

---

Теперь пароль от DC01\$ известен (он пустой). Атакующий использует эти легитимные данные для атаки **DCSync** (через протокол MS-DRSR). Он запрашивает у

контроллера домена репликацию всех хешей паролей, включая учетную запись krbtgt и администраторов домена.

Итог: создание Golden Ticket, Enterprise Admin права и абсолютный контроль над лесом.

**Практика:** В профессиональном пентесте мы часто восстанавливаем оригинальный пароль контроллера домена сразу после извлечения хешей. Это делается для предотвращения рассинхронизации DC, которая может вызвать отказ в обслуживании (Denial of Service) и быстро привлечь внимание Blue Team.

## 5. Инструментарий пост-эксплуатации

---

После публикации исследовательской работы от компании Secura, сообщество быстро разработало инструментарий. Сегодня ZeroLogon является стандартом de-facto в арсенале любого пентестера.

- **Impacket (cve-2020-1472-exploit.py):** Классический Python-скрипт, реализующий обнуление пароля.
- **Mimikatz:** Модуль `lsadump::zerologon` позволяет проверять уязвимость и эксплуатировать её прямо из памяти скомпрометированного хоста.
- **Cobalt Strike (Beacon):** Существуют BOF (Beacon Object Files), позволяющие выполнять атаку через проксированный трафик без загрузки тяжелых Python-интерпретаторов на целевую машину.

### Пример проверки уязвимости (без деструктивных действий)

---

Ниже представлен концептуальный пример вызова инструмента проверки (на базе Impacket), который только проверяет возможность прохождения аутентификации, не вызывая `NetrServerPasswordSet2`.

```
# Использование скрипта для проверки уязвимости DC01 с IP 192.168.1.10
python3 zerologon_tester.py DC01 192.168.1.10

# Ожидаемый вывод при уязвимом сервере:
# [*] Performing authentication attempts...
# [+] Success! DC01 is vulnerable to CVE-2020-1472
```

## 6. Детектирование и артефакты эксплуатации (DFIR)

---

Для инженеров Security Operations Center (SOC) и специалистов по форензике (DFIR) выявление атаки ZeroLogon после факта (post-breach) базируется на анализе логов ОС и сетевых артефактах.

## Системный журнал Windows (Event Viewer)

---

Microsoft внедрила новые Event ID для мониторинга MS-NRPC. Мониторинг лога System — ваш главный инструмент:

- **Event ID 5827 / 5828:** Запрещено подключение по уязвимому каналу Netlogon (когда сервер уже пропатчен и блокирует атаку).
- **Event ID 5829:** Разрешено подключение по уязвимому каналу (означает, что сервер работает в режиме совместимости и фиксирует использование старого протокола). Это прямой сигнал к расследованию.
- **Event ID 4742 (Security Log):** "Учетная запись компьютера была изменена". Если это событие происходит для учетной записи контроллера домена, а пароль изменен на пустой — это 100% индикатор компрометации (IoC).

## Анализ отладочного лога Netlogon

---

Для детального разбора инцидента полезно включить расширенное логирование службы.

```
:: Включение дебаг-логирования Netlogon  
nltest /dbflag:0x2080ffff
```

Логи будут записываться в C:\Windows\debug\netlogon.log. Признаком брутфорса ZeroLogon будет аномальное количество ошибок аутентификации (status 0xC0000022 — STATUS\_ACCESS\_DENIED), за которыми следует успешная транзакция изменения пароля.

**Ошибка:** Самая частая ошибка администраторов — установить патч, но не проверить логи (Event 4742) за период ДО установки патча. Уязвимость могла быть проэксплуатирована полгода назад, и злоумышленники уже создали скрытые учетные записи и "золотые билеты".

## 7. Эволюция патчей и защита инфраструктуры (2020–2026)

---

Microsoft применяла поэтапный подход к закрытию уязвимости, чтобы не сломать легальные старые системы (legasy) в корпоративных сетях.

### Фазы внедрения защиты:

---

1. **Август 2020 (Initial Phase):** Добавлен режим совместимости. Патч исправлял криптографию на самих DC, но позволял сторонним устройствам (например, старым NAS-серверам Apple или Linux Samba) использовать незащищенный RPC. Внедрены Event IDs 5827-5829.

2. **Февраль 2021 (Enforcement Phase):** Все контроллеры домена принудительно требуют защищенный RPC (Secure RPC) для канала Netlogon. Режим задается ядром ОС, игнорируя старые настройки реестра.
3. **Июнь–Июль 2023 (CVE-2022-38023):** Дальнейшее ужесточение протокола. Введены дополнительные требования к RPC Sealing. Ключ RequireSeal стал обязательным. Любой откат к уязвимым конфигурациям невозможен.

## Рекомендации по харденингу и аудиту

---

Для полного исключения риска эксплуатации ZeroLogon и смежных уязвимостей в современной инфраструктуре выполните следующий чек-лист:

- [ ] **Накатите кумулятивные обновления:** Убедитесь, что все контроллеры домена имеют обновления не старше актуального месяца (для защиты от обходов патчей, найденных в 2022-2023 годах).
- [ ] **Аудит сторонних систем:** Найдите все устройства в сети, генерирующие Event ID 5829. Обновите их прошивки (NAS, принтеры, старые RADIUS-серверы), чтобы они поддерживали Secure RPC.
- [ ] **Сетевая сегментация:** Ограничьте доступ к портам RPC (TCP/135, TCP/49152-65535) и SMB (TCP/445) на контроллерах домена. Доступ должен быть разрешен только из пользовательских и серверных VLAN, но строго запрещен из гостевых сетей, DMZ или VPN сегментов без многофакторной аутентификации.
- [ ] **Мониторинг krbtgt:** Регулярно проводите двойную смену пароля учетной записи krbtgt (раз в 6-12 месяцев или немедленно при подозрении на инцидент) для инвалидации потенциальных Golden Tickets.

Пример принудительного включения RequireSeal через PowerShell (наследие перехода к Enforcement):

```
# Настройка реестра для принудительного использования Secure RPC в Netlogon
$RegPath = "HKLM:\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters"
Set-ItemProperty -Path $RegPath -Name "RequireSignOrSeal" -Value 1 -Type DWord
Set-ItemProperty -Path $RegPath -Name "RequireSeal" -Value 2 -Type DWord
Restart-Service -Name Netlogon -Force
```

## 8. Идеи для лабораторного стенда (Practice Lab)

---

Для безопасного изучения уязвимости и настройки SIEM-систем на детектирование рекомендуется развернуть изолированный стенд.

**Требования к стенду:**

1. **Сеть:** Изолированный виртуальный свитч (Host-Only). Строго без доступа в Интернет!
2. **DC:** Виртуальная машина с Windows Server 2016 (сборка до августа 2020 года). Роль Active Directory Domain Services установлена, домен corp.local поднят.
3. **Attacker:** Kali Linux с установленным Python 3.9+ и библиотекой impacket.

#### План симуляции:

1. Настроить пересылку логов (Event Forwarding) с DC на ELK Stack или Splunk.
2. С машины атакующего запустить cve-2020-1472-exploit.py.
3. Зафиксировать сброс пароля.
4. Выполнить извлечение хешей (DCSync) через secretsdump.py.
5. Изучить сгенерированные логи (Event 4742, Netlogon debug log).
6. Смоделировать восстановление пароля машины в NTDS.DIT с помощью скрипта restorepassword.py.

**Важно:** Никогда не запускайте боевые эксплойты ZeroLogon, меняющие пароль контроллера домена, в продуктивной среде! Это приведет к рассинхронизации сервисов (DNS, Kerberos, DFS) и может вызвать полный отказ IT-инфраструктуры организации. Для тестов используйте только безопасные сканеры.

## Вывод

---

Уязвимость ZeroLogon (CVE-2020-1472) стала суровым уроком для всей IT-индустрии, продемонстрировав, как одна ошибка в использовании вектора инициализации криптографического алгоритма может обесценить все периметровые средства защиты. Несмотря на то, что Microsoft и Samba давно выпустили исправления и принудительно включили защищенные режимы RPC, эхо этой уязвимости до сих пор встречается в сетях с забытыми (Shadow IT) или неподдерживаемыми контроллерами домена.

Для команд информационной безопасности ключевым выводом является необходимость перехода от парадигмы «установили патч и забыли» к непрерывному мониторингу аномалий. Анализ сетевого трафика MS-NRPC, корреляция логов System и Security, а также регулярный аудит конфигураций — это обязательные элементы гигиены безопасности Active Directory в реалиях 2024–2026 годов.



## FAQ: Часто задаваемые вопросы

---

### 1. Нужны ли учетные данные пользователя для проведения атаки ZeroLogon?

Нет, атака является полностью неаутентифицированной. Злоумышленнику нужен только сетевой доступ к RPC-портам контроллера домена.

### 2. Можно ли эксплуатировать уязвимость через Интернет?

Только в том случае, если порты RPC (TCP 135 и высокие динамические порты) контроллера домена проброшены "наружу", что является грубейшим нарушением архитектуры ИБ. Обычно атака выполняется изнутри локальной сети (LAN/VPN).

### 3. Ломает ли атака сам контроллер домена?

Эксплуатация приводит к изменению пароля машинной учетной записи DC на пустой. В результате контроллер домена теряет доверие с другими DC, у него ломается аутентификация служб, может остановиться репликация каталога, что приведет к перебоям в работе сервисов.

### 4. Защищает ли сложный пароль администратора от ZeroLogon?

Абсолютно нет. Уязвимость эксплуатирует баг в протоколе на уровне машинных учетных записей, игнорируя пароли пользователей и администраторов.

### 5. Почему патчинг был разделен на две фазы (Initial и Enforcement)?

Потому что мгновенное отключение старого стандарта Netlogon привело бы к тому, что миллионы легитимных сторонних устройств (сетевые хранилища, принтеры, старые версии Linux) потеряли бы возможность авторизовать пользователей в домене. Администраторам дали время на обновление парка техники.

### 6. Заменяет ли патч от ZeroLogon необходимость менять скомпрометированные пароли?

Нет. Если вас атаковали ДО установки патча, злоумышленники могли извлечь krbtgt и создать Golden Ticket. Сам по себе патч закрывает "дыру", но не отзывает скомпрометированные билеты. Требуется процедура Double-Krbtgt Reset и комплексный Incident Response.

### 7. Уязвимы ли Read-Only Domain Controllers (RODC)?

Да, если у них не установлены соответствующие обновления, они также подвержены этой уязвимости и могут стать точкой входа для компрометации данных, к которым у них есть доступ.

### 8. Как быстро злоумышленник получает права Domain Admin?

При наличии готового эксплоита и сетевой связности — от 3 до 10 секунд. Брутфорс 256 значений занимает доли секунды.

### **9. Что делать, если мы обнаружили Event ID 5829 в логах пропатченного сервера?**

Это значит, что какое-то устройство в сети все еще использует уязвимую (старую) версию протокола Netlogon. Необходимо идентифицировать IP-адрес источника из лога и обновить прошивку/ОС этого устройства.

### **10. Актуальна ли угроза в 2026 году?**

Да, в рамках Red Teaming и реальных АРТ-кампаний уязвимость периодически "выстреливает" на забытых резервных контроллерах домена, старых филиальных серверах или при атаках на инфраструктуры компаний, которые годами не обновляют серверный парк из-за страха "сломать legacy-софт".